

Kyberturvallisuuslaki (124/2025 – NIS2)

11 § Poikkeamailmoitukset viranomaiselle

Toimijan on viipymättä ilmoitettava **valvovalle viranomaiselle merkittävästä poikkeamasta**. Merkittävällä poikkeamalla tarkoitetaan poikkeamaa, joka on aiheuttanut tai voi aiheuttaa vakavan palvelujen toimintahäiriön tai huomattavia taloudellisia tappioita asianomaiselle toimijalle ...

Ensi-ilmoitus on tehtävä 24 tunnin kuluessa merkittävän poikkeaman havaitsemisesta ja jatkoilmoitus 72 tunnin kuluessa merkittävän poikkeaman havaitsemisesta.

3 § Toimija → Liite I ja II

- Ilmaliikenne
- Raideliikenne
- Vesiliikenne
- Digitaalinen infrastruktuuri
- Sähkö
- Kaasu
-
-

Kyberkestävyyssäädös (Cyber Resilience Act, CRA)

Artikla 14

Valmistajan on ilmoitettava - myös olemassa olevien tuotteiden osalta:

1) ... kun valmistaja on tullut tietoiseksi **aktiivisesti hyödynnetystä haavoittuvuudesta** ...

3) ... tuotteen tietoturvaan vaikuttavista **vakavista poikkeamista**, joista se **on tullut tietoiseksi**

Ennakkovaroitusilmoitus

Valmistajan on ilmoitettava ... ilman aiheetonta viivytystä ja joka tapauksessa 24 tunnin kuluessa siitä, kun valmistaja on tullut tietoiseksi ... **CSIRT-yksikölle ja ENISAlle**

Välitön ilmoitus vain viranomaiselle

→ Ilmoitus ulkopuolisille tahoille artiklan 14 kohdan 8 mukaan

Mistä valmistaja tietää minkä komponentin haavoittuvuuksia on aktiivisesti hyödynnetty ?

1. Selvitettävä mitä ohjelmistokomponentteja ja niiden välisiä riippuvuuksia tuotteessa on → **SBOM**

2. Selvitettävä onko komponentin haavoittuvuutta hyödynnetty jo kyberhyökkäyksessä

Tieto aktiivisesti hyödynnettyjen tuotteiden haavoittuvuuksista löytyy mm.:

- Viranomaisilta
 - ☐ [Kyberturvallisuuskeskus](#)
 - ☐ [Cybersecurity and Infrastructure Security Agency](#)
- Sisäisen valvonna ja scannausten kautta
- Valmistajien **CSAF** -tietokannat
- tietoturvatutkijoilta
- kyberturvallisuusyrityksien julkaisemista raporteista
- järjestelmien toimittajilta

Ohje “Aktiivisesti hyödynnetyn haavoittuvuuden” tulkinnasta:

Haavoittuvuudet, joihin ei ole vielä korjausta (“nolla-päivä-haavoittuvuudet”), raportoidaan kun valmistajalla on luotettava näyttö siitä, että pahantahtoinen toimija on hyödyntänyt kyseistä haavoittuvuutta. Jos tutkimuslabrasta tai bug bounty -ohjelmasta tulee ilmoitus haavoittuvuudesta, kyseessä ei ole aktiivisesti hyödynnetty haavoittuvuus eikä sitä ole pakollista raportoida viranomaiselle (kts. [FAQs on the Cyber Resilience Act](#))

Cyber Security Advisory (CSAF) - Kyberturvallisuustiedote

Tuotteen valmistajan kyberturvallisuustiedote on vastuullista tiedonantoa jonka tarkoituksena on ilmoittaa asiakkaille haavoittuvuudesta ja antaa julkisesti tietoja:

- Mihin tuotteisiin ja sen versioihin haavoittuvuus vaikuttaa
- Mikä on vaikutus tuotteeseen
- Mikä haavoittuvuus on (CVE id) ja sen vakavuus (CVSS –pisteet)
- Miten haavoittuvuuden vaikutusta voidaan vähentää

Kyberturvallisuustiedote ei kuitenkaan välttämättä tarkoita, että tuotteessa olevaa haavoittuvuutta on aktiivisesti hyödynnetty kyberhyökkäyksessä.



Raportti 24 h / 72 h / 14 vrk

Aktiivisesti hyödynnetty haavoittuvuus
≠
tunnettu haavoittuvuus

TRAFICOM
Liikenne- ja viestintävirasto
Kyberturvallisuuskeskus

Etusivu >

Kriittinen haavoittuvuus FortiOS, FortiManager, FortiProxy ja FortiAnalyzer tuotteissa

HAAVOITTUVUUS 2/2026 CVSS 9.4 CVE-2026-24858

Kriittinen haavoittuvuus FortiOS, FortiManager, FortiProxy ja FortiAnalyzer tuotteissa

Julkaistu 28.01.2026 18:39

Fortinet on julkaissut tiedotteen aktiivisesti hyväksikäytetystä haavoittuvuudesta, joka koskee FortiOS, FortiManager, FortiProxy ja FortiAnalyzer tuotteita, jos niissä on aktivoituna Forticloud SSO autentikointi toiminnallisuus. Jos hyökkääjällä on FortiCloud tili ja rekisteröity laite, on hänen mahdollista kirjautua laitteille, jotka ovat rekisteröity toiselle tilille. Haavoittuvuutta on käytetty aktiivisesti hyväksi ja hyväksikäytöstä on havaintoja myös Suomessa.

Mistä valmistaja tietää onko tapahtunut vakava poikkeama ?

Vakava poikkeama on, jos:

- a)** se vaikuttaa tai voi vaikuttaa kielteisesti digitaalisia elementtejä sisältävän tuotteen kykyyn suojella arkaluonteisten tai tärkeiden datan tai toimintojen saatavuutta, aitoutta, eheyttä tai luottamuksellisuutta; tai
- b)** se on johtanut tai voi johtaa haitallisen koodin sisällyttämiseen digitaalisia elementtejä sisältävään tuotteeseen tai digitaalisia elementtejä sisältävän tuotteen käyttäjän verkko- ja tietojärjestelmiin tai ajamiseen niissä (artikla 14, kohta 5).

Esim. Kyseessä on vakava poikkeama, kun kyberturvallisuuspoikkeama vaikuttaa valmistajan kehitys-, tuotanto- tai ylläpitoprosesseihin hyökkääjän onnistuessa soluttamaan haittaohjelman julkaisukanavaan (johdanto kohta 68)



Miten valmistaja tosiasiallisesti tulee tietoiseksi vakavasta poikkeamasta tai aktiivisesti hyödynnetystä haavoittuvuudesta?

Artikla 14

Valmistajan on ilmoitettava - myös olemassa olevien tuotteiden osalta:

- 1) ... kun valmistaja **on tullut tietoiseksi aktiivisesti hyödynnetystä haavoittuvuudesta** ...
- 3) ... tuotteen tietoturvaan vaikuttavista **vakavista poikkeamista**, joista se **on tullut tietoiseksi**

Ennakkovaroitusilmoitus

Valmistajan on ilmoitettava ... ilman aiheetonta viivytystä ja joka tapauksessa 24 tunnin kuluessa siitä, kun valmistaja **on tullut tietoiseksi** ... CSIRT-yksikölle ja ENISAlle



Artikla 14 ei velvoita valmistajaa aktiiviseen haavoittuvuuksien seurantaan (kts. s. 52 [FAQs on the Cyber Resilience Act](#)). Raportointivelvollisuus syntyy vain, kun valmistaja tosiasiallisesti tulee tietoiseksi aktiivisesti hyödynnetystä haavoittuvuudesta tai vakavasta poikkeamasta.

Valmistaja voi tulla tietoiseksi aktiivisesti hyödynnetystä haavoittuvuudesta keskitetyn yhteyspisteen kautta (sähköpostiosoite ja puhelinnumero). Artiklan 13 kohta 17 mukainen yhteyspiste haavoittuvuuksien ilmoituksia varten pitää olla olemassa 12/2027. Yhteyspiste on passiivinen ilmoituskanava, ei aktiivinen seurantamekanismi.

Tietoiseksi vakavasta poikkeamasta valmistaja voi tulla milloin vain esim. havaittuaan hyökkääjän onnistuneen soluttamaan haittaohjelman julkaisukanavaan.

Kyberkestävyyslainsäädös (Cyber Resilience Act, CRA)

Artikla 14 (sovelletaan 9/2026 alkaen)

Valmistajan on ilmoitettava - myös olemassa olevien tuotteiden osalta:

- 1) ... kun valmistaja **on tullut tietoiseksi aktiivisesti hyödynnetystä haavoittuvuudesta** ...
- 3) ... tuotteen tietoturvaan vaikuttavista **vakavista poikkeamista**, joista se **on tullut tietoiseksi**

Ennakkovaroitusilmoitus

Valmistajan on ilmoitettava ... ilman aiheetonta viivytystä ja joka tapauksessa 24 tunnin kuluessa siitä, kun valmistaja **on tullut tietoiseksi** ... CSIRT-yksikölle ja ENISAlle

Vaikka CRAn artiklan 69 mukaisesti CRA ei edellytä vielä 9/2026 SBOMin tekemistä, on sen tekeminen käytännössä välttämätöntä, jotta valmistaja voi arvioida koskeeko aktiivisesti hyödynnetty haavoittuvuus sen tuotetta.

CRA ei edellytä myöskään valmistajalta aktiivisesti hyödynnettyjen haavoittuvuuksien seurantaa. Pitkäaikainen ja jatkuva liiketoiminta tosin voi edellyttää haavoittuvuuksien aktiivista seurantaa.

Lisäksi asiakkaat saattavat vaatia jonkin sisältöisen SBOMin omista käyttämistään laitteista kyberturvalain edellyttämää riskienhallintaa varten.



Raportti 24 h / 72 h / 14 vrk